

SMART INDIA HACKATHON 2025



TITLE PAGE

Problem Statement ID: 26105

Problem Statement Title: AI-Powered Continuous Cyber Risk
Quantification and Investment Optimization Platform

Theme: Blockchain & Cybersecurity

PS Category: Software

Team ID: [Team ID]

Team Name: [Registered Team Name]

Proposed Solution: ResilienceOS



to Business Decisions

TITLE: ResilienceOS — From Cyber Exposure to Business Decisions

1. Proposed Solution & Core Value Chain

- Core Mission:** A continuous cyber risk quantification and capital optimization platform that unifies security signals into business decisions.
- Continuous Pipeline:** Technical Telemetry → Business Context → Quantified Financial Exposure → 0/1 Knapsack Optimization → Verified Closed-Loop Remediation.

2. Detailed 5-Stage Solution Architecture

- 1. Aggregate:** Ingest CVE findings, SIEM authentication logs, IAM identity drift, and CSPM cloud misconfigurations.
- 2. Contextualize:** Correlate findings with asset business tiers, data classifications, and network topological attack paths.
- 3. Quantify:** Calculate rupee Expected Annual Loss ($EAL = LEF \times LM$) and 95% Value at Risk (VaR) using an Open FAIR-informed model.
- 4. Optimize:** Run counterfactual what-if simulations and solve 0/1 Knapsack DP with overlap penalties under budget constraints.
- 5. Close the Loop:** Enforce closed-loop verification where risk only decreases upon sensor evidence, updating regulatory compliance live.

3. How It Addresses the Problem & Innovation

- Key Transformation:** Replaces subjective 'Low/Med/High' heatmaps and static annual audits with continuous, mathematically grounded ₹ financial risk.
- Innovation:** Deterministic unification of Open FAIR quantification, Dijkstra topological blast radius, Knapsack budget optimizer, and Grounded AI decision support.

1. Core Technologies & Stack

- Frontend & UI:** React, JavaScript (JSX), Tailwind CSS, Recharts (Data Viz), Lucide Icons, Vite Build Pipeline.
- Core Engines:** Centralized Reactive State Store (useRiskStore), Open FAIR-informed math engine, Dijkstra shortest-path solver, 0/1 Knapsack DP optimizer.
- AI Decision Support:** Deterministic intent classifier querying live computed state with citation chips and zero hallucination risk.

2. Implementation Methodology & 12-Step Data Flow

- Ingestion & Context:** Telemetry Signals (Simulated in prototype) → Normalize Findings → CMDB Asset Association → Topological Graph Mapping.
- FAIR Quantification:** Threat Event Frequency × Vulnerability = LEF; 5-Factor Loss Magnitude (Outage + Breach + IR + Penalty + Reputation) = SLE → Expected Annual Loss (₹1.57 Cr) & 95% VaR (₹2.75 Cr).
- Optimization:** 0/1 Knapsack Dynamic Programming with pairwise overlap penalty matrix evaluates controls under budget (₹30L budget → ₹29L utilized, ₹1.38 Cr risk reduced, +376% ROSI).
- Closed Loop:** Action Assigned → Deployed → Sensor Evidence Verified → Store Recalculates EAL Live → NIST / RBI / ISO / SEBI coverage updates.

3. Prototype Validation Scope

- Current Validation:** Validated on a multi-tier fintech enterprise (7 production assets, 6 active quantified risks, 7 controls) with instant live recalculation.

1. Prototype Feasibility vs. Production Scalability

- Prototype Feasibility (Implemented):** Deterministic risk & optimization algorithms run client-side with < 2ms latency on synthetic enterprise datasets.
- Production Extension (Future):** Modular microservices using Apache Kafka event streaming, Neo4j distributed graph database, and REST webhook connectors.

2. Technical Challenges & Overcoming Strategies

- 1. Tool Integration Diversity:** Heterogeneous log formats across Qualys, Splunk, Okta, and AWS → Strategy: Normalized canonical telemetry schema with vendor adapters.
- 2. Financial Model Uncertainty:** Monetary loss estimates depend on business assumptions → Strategy: Industry-calibrated parameters (IBM Cost of Breach) with asset-level customization.
- 3. AI Trust & Hallucination:** Generative AI models hallucinate figures → Strategy: Grounded intent routing querying live deterministic store state with citation chips.
- 4. Compliance Evolution:** Regulatory frameworks (RBI, SEBI, NIST) update frequently → Strategy: Decoupled, versioned multi-framework control mapping engine.

3. Commercial & Deployment Viability

- Enterprise Value:** Integrates into existing SOC/GRC toolchains without replacing infrastructure; optimizes capital budgets and lowers cyber insurance premiums.



1. Role-Based Stakeholder Impact

- CISO:** Translates 10,000 scanner findings into monetary business exposure and presents a mathematically defensible business case for capital allocation.
- CFO & Board:** Gains actuarial visibility into Expected Annual Loss (₹1.57 Cr) and 95% VaR (₹2.75 Cr) to evaluate security spending and negotiate lower cyber insurance premiums.
- SecOps & Engineering:** Prioritizes incident response and patching based on attack path choke points and downstream blast radius rather than raw CVSS severity.
- Compliance & Audit:** Replaces 3-month manual audit prep with continuous, automated control coverage mapping across NIST CSF 2.0, RBI, ISO 27001, and SEBI CSCRF.

2. Measurable Economic & Operational Benefits

- Capital Efficiency:** Allocates security capital to maximum loss-reduction projects (+376% ROSI; ₹1.38 Cr risk reduced on ₹29L budget).
- Resource Optimization:** Focuses scarce engineering hours on P1 critical choke points, eliminating 95% of harmless scanner alert fatigue.
- Risk Reduction:** Enforces continuous verification, cutting residual portfolio exposure by 70% (₹1.57 Cr → ₹47.2 Lakhs).

3. Core Impact Chain

- Transformation Flow:** Continuous Telemetry Visibility → Business Prioritization → Optimal Budget Allocation → Verified Remediation → Lower Exposure & Audit Readiness.

1. Quantitative Risk & Vulnerability Standards

- Open FAIR Standard:** Standard for Information Security and Operational Risk Taxonomy (O-RT 1.0), Open Group.
- FIRST CVSS:** Common Vulnerability Scoring System (CVSS v3.1 / v4.0 Specification), FIRST.org.
- FIRST EPSS:** Exploit Prediction Scoring System: Forecasting Cyber Attacks in the Wild, FIRST.org / Cyentia Institute.

2. Regulatory Frameworks & Compliance Guidelines

- NIST CSF 2.0:** The NIST Cybersecurity Framework 2.0, National Institute of Standards and Technology (2024).
- RBI Master Direction:** Master Direction on Information Technology Governance, Risk, Controls and Cyber Resilience, Reserve Bank of India (2023).
- SEBI CSCRF:** Cybersecurity and Cyber Resilience Framework (CSCRF) for Regulated Entities, SEBI (2024).
- ISO/IEC 27001:2022:** Information security, cybersecurity and privacy protection — ISMS Requirements, ISO/IEC 27001:2022.
- DPDP Act 2023:** Digital Personal Data Protection Act (2023), Ministry of Electronics and Information Technology, Govt. of India.

3. Algorithmic Foundations & Research Literature

- Dijkstra, E. W. (1959):** A Note on Two Problems in Connexion with Graphs, Numerische Mathematik (Topological shortest-path reachability).
- Martello, S. & Toth, P. (1990):** Knapsack Problems: Algorithms and Computer Implementations, John Wiley & Sons (0/1 Knapsack Dynamic Programming).
- IBM Security:** Cost of a Data Breach Report (2024), IBM Security / Ponemon Institute (Calibrated financial impact parameters).